

Universidad de la
Defensa Nacional

FADENA

Ciberseguridad aplicada

Clase 3: Gestión de activos y gestión de riesgos

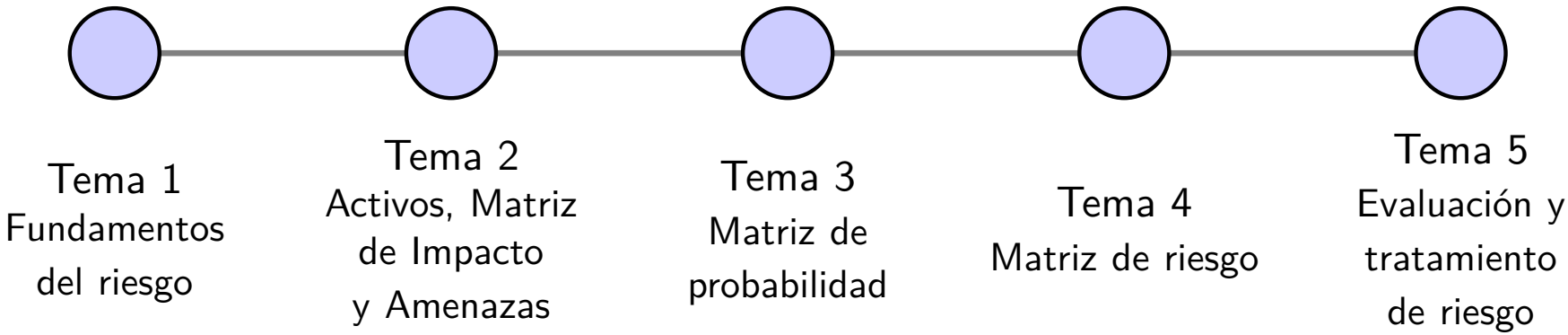
Unidad V: Gestión de riesgos

31 de agosto de 2026

Ruta de la Clase 3: Unidad IV a V

UNIDAD IV	**UNIDAD V**
Gestión de activos	Gestión de riesgos  Usted está aquí

Recorrido de la Unidad V



Tema 1 Fundamentos del riesgo
Tema 2 Activos, Matriz de Impacto y Amenazas
Tema 3 Matriz de Probabilidad
Tema 4 Matriz de Riesgo
Tema 5 Evaluación y tratamiento del riesgo

Fundamentos de la gestión de riesgos

- **Riesgo:** combinación de probabilidad e impacto
- Surge cuando una amenaza explota una vulnerabilidad
- Afecta a los activos de la organización

- La gestión de riesgos permite:
  - Tomar decisiones informadas
  - Priorizar recursos
  - Reducir impactos potenciales

Gestionar riesgos no es eliminarlos, sino comprenderlos y decidir cómo tratarlos.

Fuente: ISO/IEC 27005; NIST SP 800-30; Whitman & Mattord (2018)

Concepto de riesgo

Definición según ISO [1]

"Combinación de la probabilidad de un evento y su consecuencia" [1]

- El riesgo implica la posibilidad de que ocurra un evento no deseado
- Se evalúa en función de:
  - Probabilidad de ocurrencia
  - Impacto o consecuencia
- Generalmente se asocia a resultados negativos (pérdidas)

[1] International Organization for Standardization

Concepto de riesgo

IIA [2]

> *"La posibilidad de que ocurra un acontecimiento que tenga un impacto en el logro de los objetivos. El riesgo se mide en términos de impacto y probabilidad." [2]*

NIST [3]

> *"Riesgo es el impacto negativo resultante del ejercicio de una vulnerabilidad, considerando la probabilidad de ocurrencia." [3]*

Fuente: NIST SP 800-30

[2] The Institute of Internal Auditors
[3] National Institute of Standards and Technology

Definiciones clave

Riesgo

"La posibilidad de que ocurra un acontecimiento que tenga un impacto en el logro de los objetivos. El riesgo se mide en términos de impacto y probabilidad."

Análisis de riesgos

Proceso sistemático para estimar la magnitud de los riesgos a los que están expuestos los activos de una organización.

Activos de información

- *Información con valor para la organización*
- *Ej: datos, documentos, credenciales (contraseñas, tokens, certificaciones digitales)*

Activos de soporte

- *Elementos que permiten procesar, almacenar o transmitir información*
- *Ej: software, hardware, redes, personas*

Observación conceptual

Activo de información

En sentido estricto, el activo de información es la información en sí misma.

Sin embargo, en algunos enfoques prácticos, el concepto se amplía para incluir todos los elementos que permiten procesarla, almacenarla o transmitirla.

Definiciones clave

Impacto

Medida del daño sobre un activo derivado de la materialización de una amenaza.

Amenaza

Todo fenómeno, acción o evento, intencional o accidental, que puede producir un impacto negativo sobre los activos.

Probabilidad

Posibilidad de que ocurra un acontecimiento en un lapso de tiempo determinado.

¿Para qué realizar un análisis de riesgo?

- Permite conocer el nivel de exposición al riesgo
- Orienta la aplicación de controles de seguridad
- Facilita la evaluación de la efectividad de las medidas implementadas
- Permite evaluar la solidez del esquema de seguridad

Sirve de base para:

- Desarrollar políticas, normas y procedimientos de seguridad
- Elaborar un plan de seguridad
- Evaluar la efectividad del plan de seguridad
- Desarrollar un plan de continuidad del negocio/ de la organización

Identificación de riesgos

- Una estrategia de gestión de riesgos requiere conocer los activos de información de la organización:
  - Identificarlos
  - Clasificarlos
  - Priorizarlos
- Una vez identificados los activos:
  - Se realiza una evaluación de amenazas
  - Se identifican y cuantifican los riesgos asociados a cada activo

Idea clave

No se puede gestionar el riesgo si no se conocen primero los activos.

Fuente: Whitman & Mattord (2018)

Pasos del análisis de riesgo

Pasos del análisis de riesgo

1. **Identificación de activos** Determinar qué activos deben ser protegidos
2. **Identificación de amenazas** Reconocer eventos que podrían afectar a los activos
3. **Identificación de vulnerabilidades** Detectar debilidades que pueden ser explotadas
4. **Análisis de impacto** Evaluar las consecuencias sobre los activos
5. **Estimación de la probabilidad** Determinar la posibilidad de ocurrencia
6. **Determinación del riesgo** Combinar impacto y probabilidad
7. **Priorización de riesgos** Ordenar según nivel de criticidad

Clasificación de activos

Basado en la tríada CID:

- **Confidencialidad:** acceso sólo por entidades autorizadas
- **Integridad:** exactitud, consistencia y no alteración indebida de la información
- **Disponibilidad:** acceso a la información y a los sistemas en el momento y lugar requeridos

Extensión del modelo

La tríada CID constituye un modelo base. Sin embargo, en función del análisis de riesgo y del contexto operativo, pueden incorporarse propiedades adicionales como autenticidad, trazabilidad y no repudio.

Clasificación de activos de información

Identificación y clasificación de los activos de información

- Las dimensiones de la seguridad de la información se valora según su impacto en la operación del negocio.
- La clasificación C-I-D permite determinar la criticidad de los activos
- Define prioridades de protección
- Constituye la base para la gestión de riesgos

Veamos algunos ejemplos de escalas de impactos para la tríada CID a continuación

Construcción de las escalas de impacto

Cada escala de impacto se construye a partir de preguntas específicas que permiten asignar un nivel en cada dimensión del CID.

Confidencialidad

- ¿Qué nivel de daño se produciría si la información se divulga sin autorización?

Integridad

- ¿Qué nivel de afectación genera la alteración o pérdida de exactitud de la información?

Disponibilidad

- ¿Cuánto tiempo puede estar el activo sin estar disponible antes de afectar al negocio?

Escala de impacto para dimensión Confidencialidad

Confidencialidad: Restringe el acceso a la información.

Valor	Nivel	Descripción
1	Público	Información sin impacto significativo
2	Interno	Uso interno con bajo impacto
3	Confidencial	Acceso restringido a usuarios autorizados
4	Muy Confidencial	Impacto importante para la organización
5	Estrictamente Confidencial	Impacto crítico si se divulga

Escala de impacto para dimensión Integridad

Integridad: Protege la exactitud y totalidad de la información.

Valor	Nivel	Descripción
1	Bajo	El negocio no se ve afectado por la pérdida de integridad
2	Medio	El negocio soporta hasta 1 semana para restablecer la integridad
3	Importante	El negocio soporta hasta 48 horas
4	Vital	El negocio soporta hasta 24 horas
5	Crítico	El negocio no funciona si supera 3 horas

Escala de impacto para dimensión Disponibilidad

Disponibilidad: Asegura el acceso a la información cuando se requiere.

Valor	Nivel	Descripción
1	Bajo	El negocio no se ve afectado
2	Medio	Soporta hasta 1 semana sin el activo
3	Importante	Soporta hasta 48 horas
4	Vital	Soporta hasta 24 horas
5	Crítico	El negocio no funciona sin el activo

Escalas de Impacto en las dimensiones C, I y D

Confidencialidad

Nivel	Descripción
1	Público: sin impacto relevante
2	Uso limitado Información de baja sensibilidad. Su divulgación tiene impacto menor o controlable.
3	Interno: uso interno, bajo impacto
4	Confidencial: acceso restringido
5	Estrictamente confidencial: alto impacto

Integridad

Valor	Descripción
1	Bajo: No afecta al negocio
2	Promedio: tolera hasta 1 semana
3	Importante: tolera hasta 48 hs
4	Vital: tolera hasta 24 hs
5	Crítico: más de 3 hs es inaceptable

Disponibilidad

Valor	Descripción
1	Bajo: no afecta al negocio
2	Promedio: tolera hasta 1 semana
3	Importante: tolera hasta 48 hs
4	Vital: tolera hasta 24 hs
5	Crítico: no funciona sin el activo

Matriz de Impacto

- Define los ámbitos del negocio que pueden verse afectados ante un evento adverso
- Permite analizar las consecuencias sobre los activos

Características

- Utiliza una escala simple de valoración
- Se adapta al contexto de la organización
- Facilita la comparación entre distintos impactos

Idea clave

La matriz de impacto permite dimensionar las consecuencias de los incidentes sobre la organización.

Matriz de Impacto

Una matriz de impacto es una **estructura de evaluación** que permite representar el nivel de impacto de un activo en las dimensiones de seguridad de la información: Confidencialidad, Integridad y Disponibilidad, utilizando escalas previamente definidas.

¿Cómo clasificar los activos en las dimensiones CID?

La clasificación de los activos en las dimensiones de Confidencialidad, Integridad y Disponibilidad (CID) se realiza mediante escalas de impacto.
Estas escalas se construyen a partir de preguntas guía que permiten estimar el nivel de daño que produciría la materialización de una amenaza sobre cada dimensión.

Confidencialidad

- ¿Qué impacto tendría la divulgación no autorizada de la información?

Integridad

- ¿Qué impacto tendría la modificación o corrupción de la información?

Disponibilidad

- ¿Qué impacto tendría la indisponibilidad del activo?
- ¿Cuál es el tiempo máximo de interrupción tolerable para la organización?

Matriz de impacto - Ejemplo

Identificados los activos, se realiza una clasificación en base a las tres dimensiones de la seguridad de la información, utilizando por ejemplo la escala del ejemplo 2 anterior y queda plasmado en una matriz de impacto.

Ejemplo

Activo	**C**	**I**	**D**	**Impacto Total**[4]
Base de datos de personal	5	4	3	5
Sistema de correo electrónico	3	3	4	4
Página web institucional	2	3	5	5

C = Confidencialidad I = Integridad D = Disponibilidad

Permite asignar valores comparables a los impactos y establecer criterios de evaluación sobre los activos.

[4] Calculado como la suma de las dimensiones $(C + I + D)$. Este es un criterio posible; pueden utilizarse otras funciones de agregación.

Lectura de la clasificación CID según el criterio de impacto

Ejemplo: Base de datos de clientes

- **Confidencialidad: 5 (Impacto crítico)** → La divulgación de la información generaría consecuencias graves (datos sensibles, sanciones legales, pérdida de confianza).
- **Integridad: 5 (Impacto crítico)** → La organización no puede operar con datos incorrectos. Si la integridad no se restablece en un plazo máximo de 3 horas, el impacto se considera crítico.
- **Disponibilidad: 4 (Impacto alto)** → La indisponibilidad afecta significativamente el servicio. El activo es vital y admite una interrupción máxima de hasta 24 horas.

Interpretación

Los valores asignados responden a los umbrales de impacto definidos en la escala (por ejemplo, tiempos máximos de tolerancia).

Escala de impacto organizacional - Ejemplo II

Se presenta una escala de impacto organizacional que permite evaluar las consecuencias de un evento adverso en distintas dimensiones del negocio.

La escala utilizada va de **Insignificante (1)** a **Catastrófico (5)**.

Este análisis complementa el modelo CID (Confidencialidad, Integridad y Disponibilidad), ampliando la evaluación hacia el impacto global en la organización.

Ejemplo II: Escala de impacto organizacional

Nivel	**Económico**	**Clientes**	**Operaciones**	**Regulatorio**	**Reputación**
Insignificante (1)	$<$ \$0,01 M	Sin reclamos	Sin impacto	Sin sanciones	Sin impacto
Menor (2)	\$0,01–0,1 M	Reclamos aislados	Impacto menor	1–2 sanciones leves	Impacto leve
Moderado (3)	\$0,1–1 M	Reclamos importantes	Hasta 24h sin servicio	Hasta 3 sanciones	Difusión moderada
Significativo (4)	\$1–3 M	Reclamos masivos	Afecta operación	Múltiples sanciones	Publicidad adversa
Catastrófico (5)	$>$ \$3 M	Pérdida masiva de clientes	$>$48h sin servicio	Suspensión o cierre	Daño reputacional grave

Aclaración conceptual

Esta matriz de impacto no se limita a las dimensiones de seguridad de la información (CID), sino que extiende el análisis hacia el impacto en el negocio, considerando aspectos económicos, operacionales, regulatorios, de clientes y reputacionales.

Enfoques para el análisis de impacto

El análisis de impacto no es único ni obligatorio en una única forma de representación.

Dependiendo del objetivo y del marco metodológico, puede abordarse desde distintos enfoques:

- **CID:** Confidencialidad, Integridad y Disponibilidad
- **Negocio:** impacto económico, operativo, regulatorio, clientes y reputación
- **Continuidad del negocio (BIA):** tiempos de recuperación y criticidad de procesos
- **Legal/regulatorio:** cumplimiento normativo y sanciones
- **Técnico-operacional:** fallas, degradación y dependencias de sistemas

Estos enfoques son complementarios y su uso depende del nivel de análisis requerido.

Cálculo de Impacto: C-I-D

En gestión de riesgos de información medimos impacto en 3 dimensiones: **Confidencialidad (C), Integridad (I), Disponibilidad (D)**.

¿Cómo obtener el impacto total?
Existen distintos enfoques [5], los cuales dependen del modelo de evaluación adoptado y del nivel de detalle del análisis.

En este sentido, el impacto total no es único ni universal, sino que se define en función del criterio de modelado seleccionado, pudiendo variar según el contexto, la metodología (por ejemplo, MAGERIT) y los objetivos del análisis.

[5] Por ejemplo, suma ponderada, máximo, u otras funciones de agregación.

1. Máximo

$$\text{Impacto} = \max(C, I, D)$$

Se asume que basta con que falle una dimensión crítica. Usado en ISO 27005 y MAGERIT.

2. Suma

$$\text{Impacto} = C + I + D$$

Penaliza riesgos que afectan varias dimensiones a la vez. Requiere reescalar la matriz de riesgo.

3. Promedio ponderado

$$\text{Impacto} = W_c \cdot C + W_i \cdot I + W_d \cdot D$$

Con $\sum W = 1$. Pondera según lo que valora el negocio. Ej: $W_d = 0{,}5$ si disponibilidad es clave.

El problema: falta de criterio definido

Sin un criterio explícito pasa esto:

- Cada analista usa un método distinto → resultados no comparables
- No se puede priorizar riesgos: ¿Un 5 de "Máximo" vale lo mismo que un 8 de "Suma"?
- La auditoría pregunta ¿por qué? y no hay respuesta documentada

Regla de oro aunque no haya norma

Consistencia metodológica

Si no hay criterio estructurado externo, la organización **debe definir y documentar uno propio**. Una vez elegido, se aplica siempre igual a todos los activos.

1. Elegir enfoque: Máximo, Suma o Ponderado
2. Documentarlo en la metodología de riesgos
3. Usarlo sin excepciones para que el mapa de calor sea coherente

Conclusión: Mejor un criterio propio consistente que múltiples criterios "correctos".

De la clasificación de las dimensiones CID del activo al riesgo

¿Qué nos dice esta clasificación?

La clasificación del activo expresa el nivel de impacto que tendría un incidente sobre la información en las dimensiones de Confidencialidad, Integridad y Disponibilidad.

Esta clasificación se construye a partir de preguntas guía, que se traducen en escalas de valoración. Dichas escalas permiten evaluar los activos dentro de un modelo estructurado de análisis, como la matriz de impacto.

Del impacto en los activos a las amenazas

A partir de la matriz de impacto, se inicia la identificación de amenazas en la organización, para analizar posteriormente cómo estas pueden materializarse sobre los activos.

Etapas previas

- Identificar activos ✓
- Clasificar impacto CID ✓
- Matriz de impacto ✓

Etapas próximas

- **Identificar amenazas**
- Detectar vulnerabilidades
- Evaluar probabilidad de ocurrencia
- Matriz de probabilidad

Identificación de amenazas

Identificar las amenazas relevantes para la organización, con el fin de analizar la existencia de vulnerabilidades que puedan ser explotadas por estas y afectar a los activos.

Clasificación de amenazas

- **Ambientales** (eventos naturales o del entorno)
- **Humanas**
  - Internas / Externas
  - Estructuradas / No estructuradas
- **Tecnológicas** (fallas de sistemas, hardware, software)

Amenazas ambientales

- Dependen de condiciones físicas, geográficas y climatológicas
- Se relacionan con la infraestructura edilicia donde se encuentran los activos

Tipos de amenazas ambientales
Inundación interna
Inundación externa
Fuego interno
Fuego externo
Daño sísmico
Derrumbe
Epidemia
Rayo / tormenta eléctrica

Lectura

Cada amenaza ambiental puede materializar un riesgo sobre los activos en función de las vulnerabilidades existentes y del contexto físico y organizacional.

Medidas de mitigación

- Equipamiento de protección (UPS, sistemas contra incendios)
- Planes de recuperación ante desastres (DRP)
- Planes de continuidad del negocio (BCP)

Idea clave

Las amenazas ambientales no pueden evitarse, pero su impacto puede reducirse mediante planificación y controles adecuados.

Amenazas Humanas

- Internas / externas
- Estructuradas / no estructuradas
- Ejemplos:
  - Robo
  - Sabotaje
  - Ingeniería social

Amenazas humanas externas: Clasificación

Estructuradas

- Organizaciones o grupos organizados
- Servicios de inteligencia
- Equipos profesionales (crimen organizado)
- Alta intención y planificación

Características

- Recursos elevados
- Objetivos definidos
- Ataques persistentes

No estructuradas

- Individuos o pequeños grupos
- Motivación técnica o curiosidad
- Bajo nivel de organización

Características

- Recursos limitados
- Menor planificación
- Ataques oportunistas

Idea clave

No todas las amenazas externas tienen el mismo nivel de capacidad ni de impacto.

Amenazas humanas internas: Clasificación

Estructuradas

- Empleado con intención de causar daño
- Puede contar con apoyo externo
- Conocimientos técnicos relevantes

Características

- Acceso privilegiado
- Alto conocimiento del sistema
- Acciones planificadas

No estructuradas

- Empleados o administradores
- Curiosidad o ambición técnica
- Posible descontento laboral

Características

- Acciones no planificadas
- Errores o usos indebidos
- Impacto no intencional o limitado

Idea clave

Las amenazas internas son críticas porque combinan conocimiento del sistema con acceso directo a los activos.

Amenazas tecnológicas

- Asociadas a la tecnología utilizada por los activos de información
- Incluyen componentes de hardware, software y comunicaciones

Ejemplos

- Fallas en sistemas operativos
- Vulnerabilidades en aplicaciones
- Errores en bases de datos
- Fallas de hardware
- Problemas en redes y comunicaciones

Amenazas tecnológicas

Tipo de amenaza	**Impacto**
Fallas en sistemas de control ambiental	Sobrecalentamiento, daño a equipos
Fallas de hardware	Interrupción de servicios, pérdida de disponibilidad
Fallas en sistemas base (SO, DB)	Corrupción o pérdida de datos
Fallas en aplicaciones	Errores en procesamiento, impacto operativo
Fallas en red interna	Interrupciones de comunicación
Cortes o alteraciones eléctricas / UPS	Caída de sistemas, daño a equipos
Fallas en conexiones con terceros	Interrupción de servicios externos
Vulnerabilidades de software	Explotación de fallas, accesos no autorizados
Falta de documentación de procedimientos	Errores operativos, recuperación ineficiente ante incidentes

De las amenazas a las vulnerabilidades

Una vez identificadas las amenazas y evaluado el impacto potencial sobre los activos, se avanza hacia el análisis de las debilidades del sistema.

Paso siguiente en el análisis de riesgo

Etapas previas

- Identificación de activos ✓
- Clasificación del impacto CID ✓
- Matriz de impacto ✓
- Identificación de amenazas ✓

Etapas próximas

- **Detección de vulnerabilidades**
- Evaluación de la probabilidad
- Construcción de matriz de probabilidad

Vulnerabilidades

Una vulnerabilidad es una debilidad o condición que puede ser explotada por una amenaza.

Características

- Pueden existir en distintos niveles del sistema
- No implican necesariamente un incidente por sí mismas
- Aumentan la probabilidad de que una amenaza se materialice

Tipos de vulnerabilidades

- Técnicas (software, hardware)
- Organizativas (procesos, políticas)
- Humanas (errores, desconocimiento)

Idea clave

Una amenaza solo puede materializarse si existe una vulnerabilidad que pueda ser explotada.

Identificación de vulnerabilidades

La identificación de vulnerabilidades no es un proceso trivial ni intuitivo.

Requiere un análisis sistemático de los distintos componentes del sistema y su contexto operativo.

Metodologías como **MAGERIT** proporcionan catálogos estructurados que incluyen:

- Amenazas
- Vulnerabilidades
- Salvaguardas

Idea clave

El uso de estos catálogos permite estructurar el análisis y reducir la omisión de debilidades relevantes.

De Impacto a Probabilidad

Hasta este punto, el análisis se centró en el **impacto**, es decir, en las consecuencias que tendría la materialización de un evento sobre los activos.

Ahora se introduce una nueva dimensión del análisis:

Nuevo enfoque

Se analiza la **probabilidad de ocurrencia** de eventos que puedan afectar negativamente a los activos.

¿Qué se evalúa en la probabilidad?

La probabilidad se centra en la posibilidad de que ocurra un evento adverso.

- Exposición del activo a amenazas
- Frecuencia de intentos o incidentes
- Existencia y efectividad de controles
- Historial de eventos similares

Preguntas guía para estimar la probabilidad

La escala de probabilidad se construye a partir de preguntas como:

- ¿Qué tan expuesto está el activo a amenazas?
- ¿Con qué frecuencia se presentan intentos de ataque o fallas?
- ¿Existen controles efectivos para reducir la ocurrencia?
- ¿Se han registrado incidentes similares previamente?

Construcción de la escala de probabilidad

A partir de estas preguntas, se define una escala ordinal que permite clasificar la probabilidad de ocurrencia.

Idea clave

La probabilidad no es un valor exacto, sino una estimación basada en exposición, vulnerabilidades y controles.

Aplicación de la escala

La escala de probabilidad se aplica a los activos de la organización para estimar la frecuencia con la que podrían materializarse amenazas sobre ellos.

A partir de la escala de probabilidad, se construye la matriz de probabilidad, que permite asignar a los activos de la organización un nivel de probabilidad asociado a la frecuencia de ocurrencia de eventos adversos.

Matriz de Probabilidad

Una matriz de probabilidad es una **estructura de evaluación** que permite estimar la frecuencia de ocurrencia de una amenaza sobre los activos de la organización, utilizando una escala ordinal previamente definida.

Esta estructura facilita la clasificación homogénea de la probabilidad de materialización de eventos adversos en función de su recurrencia temporal.

Características

- Utiliza una escala simple de valoración
- Se basa en períodos de tiempo relevantes para el negocio/la organización
- Permite estimar la recurrencia de eventos adversos

Idea clave

La probabilidad indica qué tan frecuente puede ocurrir un evento que afecte a la organización.

Ejemplo de escala de probabilidad

Nivel	**Descripción**	**Frecuencia anualizada**
Muy probable (5)	Se espera que ocurra en la mayoría de las circunstancias	$\geq$ 1 vez por año
Probable (4)	Probablemente ocurrirá en la mayoría de las circunstancias	1 vez cada 2,5 años (0,75)
Posible (3)	Podría ocurrir algunas veces	1 vez cada 5 años (0,5)
Incierto (2)	No es muy probable que ocurra	1 vez cada 7 años (0,25)
Improbable (1)	Solo ocurriría en casos excepcionales	$\leq$ 1 vez cada 10 años (0,1)

Idea clave

La probabilidad permite estimar la frecuencia con la que un evento puede materializarse.

Ejemplo de Matriz de Probabilidad

Evento de amenaza	**Probabilidad (1–5)**	**Activo afectado**
Intentos de acceso no autorizado / errores humanos	3 (Posible)	Base de datos de personal
Phishing, malware y robo de credenciales	4 (Probable)	Sistema de correo electrónico
Ataques externos automatizados (DDoS, escaneo, explotación)	4 (Probable)	Página web institucional

Idea clave

La probabilidad se estima a partir de la frecuencia de los eventos de amenaza, los cuales se relacionan posteriormente con los activos afectados.

De las probabilidades al Riesgo

El riesgo se determina a partir de la combinación entre la probabilidad de ocurrencia de una amenaza y el impacto sobre el activo afectado.

Etapas previas

- Identificación de activos ✓
- Clasificación del impacto CID ✓
- Matriz de impacto ✓
- Identificación de amenazas ✓
- Detección de vulnerabilidades✓
- Evaluación de la probabilidad ✓
- Construcción de matriz de probabilidad ✓

Etapas próximas

- Calculo del Riesgo
- Escala del riesgo
- Tratamiento del Riesgo
- Controles/ Salvarguadas

Componentes del riesgo

- **Impacto:** consecuencias de la materialización de una amenaza sobre un activo, afectando sus dimensiones de seguridad (C, I, D)
- **Probabilidad:** frecuencia de ocurrencia de la amenaza

Riesgo

El riesgo resulta de la interacción entre activos, amenazas y vulnerabilidades, que determina la posibilidad de ocurrencia de un evento con impacto sobre la organización.

Fuente: NIST SP 800-30 [3]; MAGERIT v3 [4]

Matriz de Riesgo

- La matriz de riesgo combina la **probabilidad de ocurrencia** y el **impacto** de un evento.
- Permite clasificar los riesgos en niveles de severidad para su tratamiento.

Matriz de Riesgo

Prob.	**1** Insig.	**2** Menor	**3** Moderado	**4** Signif.	**5** Catastr.
Muy probable (5)	Medio	Alto	Extremo	Extremo	Extremo
Probable (4)	Bajo	Medio	Alto	Extremo	Extremo
Posible (3)	Bajo	Medio	Alto	Extremo	Extremo
Incierto (2)	Bajo	Medio	Alto	Alto	Extremo
Improbable (1)	Bajo	Bajo	Medio	Alto	Alto

Lectura y escala de riesgo

- Bajo (1–4): aceptable
- Medio (5–9): monitorear
- Alto (10–14): tratar
- Extremo (15–25): acción inmediata

Construcción de la Matriz de Riesgo

El riesgo se obtiene combinando la **probabilidad de un evento de amenaza** con el **impacto del activo afectado**.

Integración de información

- Impacto: derivado de la clasificación CID del activo
- Probabilidad: asociada al evento de amenaza

Cálculo conceptual del riesgo

$$Riesgo = Probabilidad \times Impacto$$

Ejemplo de Matriz de Riesgo

Evento de amenaza	**Activo afectado**	**P**	**I**	**Riesgo**
Acceso no autorizado / errores humanos	Base de datos de personal	3	5	15
Phishing / malware / robo credenciales	Correo electrónico	4	4	16
DDoS / explotación externa	Página web institucional	4	5	20

Lectura

El riesgo surge de combinar la probabilidad de ocurrencia (P)del evento con el impacto (I) sobre el activo afectado.
En este ejemplo, los escenarios analizados presentan valores de riesgo de **15, 16 y 20**, los cuales corresponden a niveles de **riesgo extremo**.

Opciones de Tratamiento

- Reducir (controles de seguridad)
- Transferir (seguros, terceros)
- Aceptar (riesgo asumido)
- Evitar (eliminar la actividad)

Tipos de Controles o Salvaguardas

Los controles de seguridad son medidas implementadas para reducir la probabilidad de ocurrencia de amenazas y/o su impacto sobre los activos.

- **Controles técnicos:** mecanismos tecnológicos (firewalls, antivirus, cifrado, IDS/IPS)
- **Controles físicos:** protección de infraestructura (accesos, cerraduras, CCTV)
- **Controles organizacionales:** procedimientos y procesos internos
- **Políticas de personal:** formación, concientización y gestión de usuarios

Plan de Tratamiento del Riesgo

El plan de tratamiento del riesgo define cómo se gestionan los riesgos identificados a partir del análisis de activos, amenazas y vulnerabilidades.

Componentes del plan

- Definición de acciones de tratamiento (mitigar, transferir, evitar o aceptar)
- Asignación de responsables para su implementación
- Estimación de recursos técnicos, humanos y económicos
- Priorización de escenarios de riesgo críticos

Idea clave

El tratamiento del riesgo no elimina la incertidumbre, sino que la gestiona mediante decisiones organizacionales basadas en el nivel de riesgo residual aceptable.

Riesgo Bruto vs Riesgo Residual

Riesgo bruto

- Se calcula sin considerar controles de seguridad
- Representa el escenario inicial de exposición
- Depende de impacto y probabilidad teórica

Interpretación

- Nivel máximo de riesgo posible
- Punto de partida del análisis

Riesgo residual

- Se calcula considerando controles implementados
- Refleja la reducción del riesgo por mitigación
- Depende de impacto y probabilidad ajustados

Interpretación

- Riesgo efectivamente presente
- Base para la toma de decisiones

Idea clave

El objetivo de la seguridad de la información es gestionar el riesgo, aplicando controles que lo reduzcan hasta un nivel aceptable denominado riesgo residual.

Riesgo bruto y Riesgo residual

Modelo conceptual

- Riesgo bruto: R_{bruto} nivel de riesgo antes de aplicar controles
- Riesgo residual : $R_{residual}$ nivel de riesgo luego de implementar salvaguardas
- Decisión de tratamiento: aceptar, mitigar, transferir o evitar

Formalización

$$R_{residual} = R_{bruto} - \text{efecto de los controles}$$

Interpretación

- El riesgo residual se compara con el nivel de riesgo aceptable
- Si excede el umbral $\rightarrow$ requiere tratamiento adicional
- Si es aceptable $\rightarrow$ puede ser asumido por la dirección

Ejemplo de Riesgo Bruto vs Residual

Impacto calculado como suma de CID (C + I + D)

Amenaza	**Activo específico**	**P**	**I**	R_{bruto}	**Controles**	$R_{residual}$
Acceso indebido por error humano	BD personal de empleados	3	5	15	MFA, monitoreo	9
Phishing dirigido a cuentas institucionales	Sistema de correo corporativo	4	4	16	filtros anti-phishing, capacitación	8
Ataque DDoS a portal web institucional	Web institucional pública	4	5	20	WAF, mitigación de tráfico	10

Lectura

- El impacto se calcula a partir de la agregación de las dimensiones CID del activo
- Cada riesgo representa un escenario específico amenaza–activo
- El riesgo residual refleja la reducción lograda mediante controles

Gestión continua del riesgo

Naturaleza del riesgo

- El riesgo es dinámico: evoluciona con el entorno tecnológico y organizacional
- Cambia en función de activos, amenazas y vulnerabilidades
- No puede considerarse un estado fijo

Implicancias

- Requiere monitoreo permanente
- Exige revisión periódica de controles
- Depende del contexto organizacional

Idea clave

La gestión del riesgo no es un evento aislado, sino un proceso continuo de adaptación.

Fuente: ISO/IEC 27005; ISO 31000

Ciclo de gestión del riesgo

Proceso iterativo

$$\text{Activos} \rightarrow \text{Amenazas/Vulnerabilidades} \rightarrow \text{Probabilidad} + \text{Impacto} \rightarrow \text{Riesgo} \rightarrow \text{Tratamiento} \rightarrow \text{Monitoreo} \rightarrow \text{Mejora}$$

Componentes del ciclo

- Evaluación del riesgo inherente (bruto)
- Aplicación de controles de seguridad
- Obtención del riesgo residual
- Monitoreo y revisión de los riesgos
- Retroalimentación y mejora continua

Idea clave

La gestión del riesgo es un proceso continuo: los riesgos se evalúan, se tratan y se revisan para mantenerlos dentro de niveles aceptables.

Gestión operativa del riesgo

En la práctica, la gestión del riesgo implica:

- Identificar cambios en los activos o en la infraestructura
- Detectar nuevas amenazas
- Reevaluar vulnerabilidades existentes
- Revisar y ajustar los controles de seguridad

Como resultado:

- Se actualiza la evaluación del riesgo
- Se revisa el riesgo residual
- Se pueden establecer nuevas prioridades de tratamiento

Idea clave

La gestión del riesgo requiere una revisión continua para responder a los cambios que afectan a la organización.

¿Qué pasa con lo que no conocemos?

Una limitación del análisis de riesgos

El análisis de riesgos se realiza a partir de la información disponible. Sin embargo, no necesariamente conocemos todas las amenazas, vulnerabilidades o escenarios que pueden afectar a un sistema.

Por ejemplo:

- puede existir una vulnerabilidad que todavía no ha sido descubierta;
- puede aparecer una nueva forma de ataque;
- un escenario conocido puede combinarse con otros factores de una manera que no habíamos previsto.

¿Y qué ocurre con una vulnerabilidad desconocida?

Una vulnerabilidad puede existir antes de que sea identificada por quienes desarrollan o protegen el sistema. Este tipo de situaciones puede dar lugar a escenarios como los **zero-day**, en los que una vulnerabilidad puede ser explotada antes de que exista una solución disponible.

Una dificultad para la gestión de riesgos

No podemos valorar con precisión aquello que todavía no conocemos.

Esto nos lleva a reconocer algo inevitable, tanto en la gestión de riesgos como en nuestra vida:

no podemos conocerlo todo.

Y esa imposibilidad nos enfrenta a:

la incertidumbre.

Cuando no podemos anticiparlo todo

Si no podemos conocer ni prevenir todos los escenarios posibles, la seguridad no puede depender exclusivamente de anticiparse a cada amenaza. También es necesario desarrollar capacidades que iremos viendo en esta materia para:

- **resistir** condiciones adversas;
- **detectar** eventos;
- **responder** ante incidentes;
- **recuperarse** después de un compromiso;
- **adaptarse** frente a nuevas condiciones.

Ciberresiliencia

La ciberresiliencia busca que los sistemas puedan anticipar, resistir, recuperarse y adaptarse frente a condiciones adversas, ataques o compromisos. [5]

Una idea clave

Gestionar riesgos no significa conocerlo todo.

Significa identificar y analizar aquello que podemos conocer, **asumiendo que existe incertidumbre**.

Y, frente a aquello que no podemos anticipar completamente, desarrollar capacidades para **resistir, responder y recuperarnos**.

La gestión de riesgos y la ciberresiliencia se complementan.

¡¡Muchas gracias!!

Volvemos al campus virtual

Por favor, recuerden realizar la Actividad Obligatoria
de la Unidad IV y V que están publicas en el campus.

Fecha límite: Lunes 7/09 a las 23:59 hs



Referencias I


"Iso/iec 27005: Information security risk management," 2018.


The Institute of Internal Auditors, "International professional practices framework (ippf)," 2017.


NIST, "Guide for conducting risk assessments (sp 800-30 rev. 1)," tech. rep., National Institute of Standards and Technology, 2012.


Ministerio de Hacienda y Administraciones Públicas, "Magerit versión 3: Metodología de análisis y gestión de riesgos de los sistemas de información. libro iii: Guía de técnicas," 2012.
Disponible en:
`https://www.ar-tools.com/doc/magerit/2012_Magerit_v3_libro3_guia%20de%20tecnicas_es_NIPO_630-12-171-8.pdf`.

Referencias II



R. Ross, V. Pillitteri, R. Graubart, D. Bodeau, and R. McQuaid, "Developing cyber-resilient systems: A systems security engineering approach," Tech. Rep. NIST SP 800-160 Vol. 2 Rev. 1, National Institute of Standards and Technology, Dec. 2021.